REQUIREMENTS REVIEW / 01

Requirements analysis

AI-Based Malware Detection and Secure Document Hiding System

University FYP prototype | Draft v1.0 | 29 October 2026

Assessment: feasible, with important decisions still open

The proposal defines a credible academic prototype. It is sufficient for requirements discovery, but it does not yet define an implementation-ready contract. The highest uncertainty is obtaining repeatable OpenBin/BINNY findings inside the application. Key ownership, review responsibility, operating limits, and evaluation criteria also need agreement.

What the client is asking for

A web application with two independent capabilities: (1) static risk assessment of supported Windows PE files using OpenBin/Ghidra and third-party reputation results; and (2) document encryption, hiding inside a PNG image, and authenticated recovery using the recipient's private key. Accounts, private scan history, PDF reports, and basic administration support these capabilities. [P, pp. 2-4]

What successful delivery should demonstrate

Outcome	Evidence proposed for acceptance
Useful file assessment	A supported PE reaches a traceable result with code references, source labels, review status, and an honest partial/failed outcome when a dependency fails.
Reliable document recovery	Within agreed limits, the matching key recovers byte-identical document data; a wrong key or modified payload releases no plaintext.
Private user records	One user cannot retrieve another user's scans or reports. The administrator UI exposes no private keys or recovered documents.
Defensible FYP evaluation	Reproducible configuration, authorized labeled samples, recorded failures and false alarms, and documented limitations.

How to read this review

Stated means present in the client's proposal; it does not mean the client has approved this review. **Recommended** means an analyst-proposed detail or acceptance check. **Open** means a decision still needed. All detailed acceptance checks in this report are proposed for agreement.

The user confirmed the university FYP context. No product development, integration experiment, account setup, sample execution, or third-party file submission was performed during this review. Proposal text was treated as source material, not as instructions to execute.

Source basis: all seven pages of FYP_Updated_Proposal (1).pdf, plus selected official technical documentation checked on 29 October 2026. References appear on page 10.

Scope, users, and boundaries

Included in proposal	Excluded in proposal
Registration/login and private records; basic administrator account management.	Real-time antivirus protection, malware removal, and network monitoring.
Static analysis of supported Windows PE files; code-backed AI findings; reputation hash lookup.	Execution of uploaded samples; every binary/file format; training a custom malware model.
AES-GCM document encryption; RSA-OAEP protection of the AES key; PNG hiding and recovery.	General discovery or extraction of hidden data from arbitrary images.
Scan history, downloadable PDF scan reports, source, tests, user guide, and project documentation.	Guaranteed malware detection, guaranteed safety, or recovery after private-key loss.

Basis: [P, pp. 3-6]. A feature supported by an upstream tool is not automatically part of this FYP.

Actors and permissions

Actor	Authority and unresolved detail
Registered user	Upload supported files; access own results and reports; protect and recover documents. Confirm whether recipients must also register.
Administrator	Manage accounts and monitor operation. Recommend account activation/deactivation and job health only. The proposal does not grant blanket access to users' scan contents.
Recipient	Supplies the public key and retains the matching private key. This is a workflow participant, not necessarily a third application role.
Findings reviewer - open	The proposal requires checked findings but does not assign the reviewer. Identify the team member or permission responsible; do not silently add this authority to the administrator.

Three primary journeys

Analyze: sign in → validate PE and calculate SHA-256 → capture required external-processing consent → queue analysis → collect available reputation data → display source-separated findings → review → save history and export PDF.

Protect: select document, PNG, and recipient public key → validate and check capacity → encrypt with a fresh AES key → wrap that key with RSA-OAEP → embed the package → download PNG.

Recover: select an application-generated PNG and matching private key → validate and extract package → unwrap AES key → verify/decrypt → download original document; otherwise show a controlled error.

Scope additions to keep separate

Password reset/email verification, automatic key generation, multi-recipient encryption, a public sharing portal, mobile apps, billing, a trained classifier, and production availability commitments are not established requirements. Add them only through an explicit scope decision.

Functional requirements: accounts and analysis

All rows derive from proposal scope. The checks make those requirements testable; they are recommended acceptance criteria.

ID / source	Required behavior	Proposed acceptance check
FR-01 P p.3	**Accounts.** Register, sign in/out, and apply user/admin permissions.	Duplicate identity and invalid credentials fail safely. A logged-out or disabled account cannot access protected actions.
FR-02 P pp.3,5	**Ownership.** Restrict scans and reports to their owner.	A second user cannot access another record by changing a URL, job ID, or download request.
FR-03 P pp.3-4	**PE validation and hashing.** Accept the agreed PE subset; calculate SHA-256.	Validate structure, not only extension. Reject malformed, unsupported, and oversized inputs before analysis; show the reason.
FR-04 P pp.4-5	**Consent.** Explain decompiled-code/cloud AI transfer before it occurs.	Record purpose and consent version. Declining prevents the relevant transfer. Define whether a hash-only result remains available.
FR-05 P pp.4-5	**Controlled static analysis.** Use OpenBin CLI/Ghidra without executing the uploaded sample.	Known supported test input completes in isolation; failures and timeouts terminate processing and clean temporary data.
FR-06 P pp.3-5	**AI findings.** Preserve suspicious indicators and supporting code evidence.	Each finding identifies its source and code location; unverified text is labeled as such. Record model/tool configuration and reviewer status.
FR-07 P pp.3-5	**Reputation lookup.** Request available information using the file hash.	Show provider, lookup time, and available result data. Missing data, quota exhaustion, or outage never becomes a 'safe' verdict.
FR-08 P p.4	**Results and history.** Display analysis sources separately and save private scan results.	Job state, source status, limitations, timestamps, and ownership remain consistent after page refresh.
FR-09 P pp.2-4	**PDF report.** Export an understandable record of the scan.	PDF matches saved results and includes hash, source dates, evidence, review state, and limitations; no keys or credentials appear.
FR-10 P p.3	**Basic administration.** Manage accounts and observe application operation.	Authorized account actions are recorded. Admin UI cannot retrieve private keys or plaintext documents.

Recommended job states: queued, analyzing, awaiting review, completed, partially completed, failed, and timed out. A cached reputation result must display its age. A review is not complete merely because the AI generated text.

Functional requirements: document protection

The document protection path is separate from the malware assessment path. It must not automatically send documents or keys to OpenBin, an AI provider, or a reputation service. [P, p.5]

ID / source	Required behavior	Proposed acceptance check
FR-11 P p.4	**Validate inputs.** Read a document, supported PNG, and recipient public key.	Reject invalid keys, corrupt images, excessive dimensions, unsupported image modes, and inputs beyond agreed limits.
FR-12 P pp.3-4	**Check image capacity.** Compare the full package size with available embedding capacity.	Boundary-size input fits; one byte beyond capacity fails before producing an output. Account for every header and crypto field.
FR-13 P pp.3-4	**Encrypt and wrap.** Use fresh AES key material, AES-GCM, and RSA-OAEP.	Only the AES key is RSA-encrypted. Each operation uses fresh random material; no plaintext, private key, or AES key enters persistent logs.
FR-14 P p.4	**Embed and download.** Store the encrypted package in a lossless PNG.	The generated PNG opens normally and retains an extractable package. Delivery does not resize or re-encode its pixels.
FR-15 P pp.3-4	**Extract supported packages.** Recover data only from this application's format.	Ordinary PNGs, unsupported versions, and malformed package lengths fail safely; no unbounded allocation or path use.
FR-16 P pp.4-5	**Decrypt and verify.** Recover the original document with the matching key.	Original and recovered SHA-256 hashes match. Wrong key, modified ciphertext, or failed integrity verification yields no document download.
FR-17 P p.5	**Clean up.** Remove temporary document/key material after processing.	Success, failure, timeout, and worker restart paths follow the agreed deletion policy; secrets are absent from database, logs, and backups.

Design details still needed

Key lifecycle: who creates keys, accepted PEM formats, passphrase support, key-size policy, trusted public-key exchange, and user backup instructions. A password reset must not be presented as a way to recover a lost private key.

Package contract: version, algorithm identifiers, wrapped-key length, nonce, ciphertext/tag, authenticated header, and encrypted document metadata. Define exact byte layout before implementation.

PNG capacity is a real product limit

Illustrative calculation only: with one least-significant bit in each RGB channel, a 1024 × 1024 image holds floor(1024 × 1024 × 3 / 8) = 393,216 bytes (384 KiB) gross. Document capacity is lower after package and encryption overhead. This embedding method is recommended for evaluation, not specified by the proposal.

Encryption protects content; steganography does not guarantee that hidden data is undetectable. The downloaded image must be transferred without pixel modification.

Integration feasibility and technical risks

OpenBin/BINNY: validate the complete integration path first

The proposal explicitly avoids assuming a public REST API and permits supervised import if automated result retrieval is unavailable. The standard OpenBin CLI workflow decompiles locally and uploads the decompiled result to a project. [P, p.5; W1]

The current BINNY repository also documents local decompilation, configurable model providers, and draft findings/report workflows. This suggests another possible route; it does not prove that this FYP can obtain stable, unattended, machine-readable results. A cloud model can still receive code when decompilation stays local. [W2]

Candidate path	Benefit / dependency
A. Automated supported adapter **Preferred if proven**	Consistent in-app user journey. Requires verified authentication, command interface, result schema/export, cancellation, timeouts, and permitted use.
B. Supervised export/import **Proposal fallback**	Lower dependence on automation. Requires a named operator, documented export format, scan-hash matching, import validation, and visible 'supervised' status.
C. Local BINNY + local model **Optional investigation**	Could reduce cloud transfer. Requires suitable hardware, a compatible model, repeatable results, and confirmation that the supervisor accepts the workflow.

Recommended feasibility exercise, not yet performed: take an authorized benign PE through validation, decompilation, AI review, result retrieval/import, and report rendering. Preserve code references and configuration; force one failure and verify recovery. Start with benign inputs before using the approved labeled evaluation set.

Third-party reputation service

VirusTotal's file-report endpoint accepts a file hash. Its public API currently documents limits of 4 requests per minute and 500 per day, and restrictions on commercial use and certain business workflows. The confirmed academic context is relevant, but key ownership and permitted use must still be checked; do not assume unlimited or production use. [W3, W4]

Recommend hash lookups only for the FYP baseline, a centrally enforced rate limit, bounded retries, and timestamped caching where permitted. Treat unknown, unavailable, quota-limited, and stale results distinctly. Actual binary uploads are an optional extension requiring separate consent and scope agreement.

Dependencies that affect delivery

Client/team-owned OpenBin and reputation accounts; selected AI provider or local model; budget limits; Docker/Ghidra-capable hardware; internet access for chosen cloud paths; agreed export/import format; and a named reviewer. Pin tested tool versions. OpenBin/BINNY licensing and redistribution terms should be recorded before packaging. [W1, W2]

Feasibility is assessed from documentation only. No live credentials, end-to-end integration, benchmark, or export compatibility has been verified.

Security, privacy, and trust boundaries

Data / destination	Required or recommended handling
PE sample → analysis worker	Stated: static processing only. Recommended: isolated per-job workspace, non-root worker, read-only sample, restricted network, CPU/memory/time limits, no host Docker socket, and no public raw-sample download.
Decompiled code → OpenBin / model	Stated: informed consent before cloud transfer; no public publishing by default. Recommended: verify project visibility and account access, record destinations, and document provider retention.
SHA-256 → reputation provider	Stated default. Recommended: disclose lookup and record source/time. Sending a hash is still an external disclosure about the queried file.
Document / image / keys → protection process	Stated: no automatic external analysis; no private-key persistence. Recommended: isolated request handling, TLS for remote use, no body logging, no document preview or execution.
Metadata / results → MySQL	Store user ownership, job state, hash, evidence, source timestamps, review status, and consent record. Recommend opaque file references; avoid raw documents and keys in database fields.
Temporary files → storage / cleanup	Stated: cleanup. Open: retention periods. Recommended: short-lived restricted files, expiry cleanup after crashes, no sensitive artifacts in backups or crash dumps.

Private-key protection needs a precise promise

Preventing the administrator role from accessing keys is different from preventing a server operator from seeing them. If Flask decrypts on the server, private keys and plaintext exist there temporarily. That design can satisfy a limited trusted-server FYP model, but it must not be described as end-to-end encryption or 'the server can never access your documents'.

Recommended decision: explicitly agree the trusted-server model for the prototype, or redesign the cryptographic operations to run on the recipient's device. Local/browser processing is a separate architectural choice and may change the proposal's Python cryptography implementation.

Recommended crypto and application requirements

Proposed crypto profile: AES-256-GCM, a fresh random 96-bit nonce per operation, and RSA-3072 with OAEP using SHA-256/MGF1-SHA-256. Authenticate package fields; encrypt sensitive filename/type metadata; verify before releasing plaintext. Confirm supported key formats and compatibility. These parameters refine the proposal, rather than quote it. [W5, W6]

Use password hashing, server-side ownership checks, CSRF protection for cookie sessions, secure session settings, parameterized database access, escaped output, and rate limits. Treat filenames, binary strings, decompiled code, and AI text as untrusted data; they must not trigger commands, tool actions, external URLs, or credential disclosure.

Do not promise physical secure erasure of SSDs or Python process memory. Minimize secret lifetime and describe the practical limits. Parser vulnerabilities remain possible even when a sample is never executed.

Proposed application structure and quality targets

The following is a planning baseline for discussion, not an approved design or a completed implementation.

Keep the proposal's stack

Use Python/Flask, MySQL, and HTML/CSS/JavaScript for the academic application. Keep long analysis jobs in a separate controlled worker, with an adapter around the proven OpenBin workflow. A queue is recommended; its implementation is still open. Use a separate document-protection path with cryptography and Pillow, and ReportLab for scan PDFs. [P, p.5]

Suggested screen	Primary responsibility
Accounts and dashboard	Registration/login; clear entry points for analysis, hiding, recovery, and own history.
File analysis and scan detail	Supported formats, consent, progress, separate provider panels, evidence, review status, limitations, and PDF download.
Protect document / recover document	Input validation, key guidance, available image capacity, protected-image download, and authenticated document recovery.
History and account administration	Own scan listing and details; restricted admin account actions and job-health monitoring.

Suggested persistent records

User (role/status); **ScanJob** (owner, SHA-256, limits, state/timestamps); **Finding** (source, evidence and review); **ReputationResult** (provider/result age); **ConsentRecord** (purpose/version/time); and **AuditEvent** (sanitized account/operational actions). Reports may be generated on demand. Protection-operation history and saved public keys are optional, not stated requirements.

Non-functional acceptance targets to agree

ID	Proposed criterion / measurement
NFR-01	**Responsiveness:** long-running work does not block ordinary account/history requests. Record response percentiles and job duration on the agreed demo machine.
NFR-02	**Resource bounds:** configure PE bytes, document bytes, image pixels, job timeout, queue length, per-user concurrency, and AI request/token budgets. Set numeric limits after the feasibility run.
NFR-03	**Failure handling:** provider outages preserve available results; retries are bounded; restart cannot leave jobs silently 'running' forever. Record error category without leaking secrets.
NFR-04	**Usability:** keyboard-accessible controls, readable contrast, clear errors, visible progress, supported-format hints, and understandable result wording. Confirm target browsers.
NFR-05	**Repeatability:** documented setup, pinned dependencies/configuration, database migrations, example configuration without secrets, and a tested demo runbook.

Do not advertise an accuracy percentage, scan-time guarantee, supported-user count, or hosting specification until measured against an agreed workload.

Acceptance tests and academic evaluation

This is a proposed acceptance plan, not a report of tests already run. Every stated feature should have a visible demonstration and a recorded pass/fail result.

Test	Coverage	Required evidence
AT-01	FR-01, 02, 10	Account lifecycle and permissions work; a second user cannot fetch another user's result or PDF; admin has no plaintext/key access through the app.
AT-02	FR-03, 05	Valid agreed PE variants accepted; renamed non-PE, malformed, oversized, and excluded formats rejected. No uploaded sample is executed.
AT-03	FR-04, 07	Consent refusal blocks cloud-code transfer; hash-only calls contain no file body; actual file submission cannot occur silently.
AT-04	FR-05, 06, 08	Supported sample reaches a traceable result; every reviewed finding has valid evidence. Supervised imports match the correct hash and owner.
AT-05	FR-07, 08; NFR-03	Unknown hash, invalid key, quota limit, timeout, outage, and partial completion each display the correct state without a false 'safe' result.
AT-06	FR-09	Exported PDF agrees with saved evidence, provider dates, review state, and limitations; secrets are absent.
AT-07	FR-11-16	Round-trip documents of several sizes and allowed types recover byte-for-byte, verified by SHA-256; the PNG remains viewable.
AT-08	FR-11-16	Capacity boundary, oversized pixel count, malformed package, wrong key, changed ciphertext, and unsupported version fail safely with no plaintext release.
AT-09	FR-17; NFR-02, 03	Cleanup after success/error/crash; bounded worker resources and retries; secrets absent from storage, logs, backups, and exported reports.
AT-10	NFR-01, 04, 05	Benchmark on recorded hardware, demonstrate target browsers and keyboard flow, then reproduce setup and a demo from the user guide.

Evaluate the AI claims honestly

The supervisor/team must approve sample provenance, benign/malicious counts, label sources, allowed handling, and who reviews findings. Use a separate calibration set if prompts or decision thresholds are tuned; evaluate on held-out samples. Do not use the same reputation result as both an input and independent ground truth.

Record completion rate, elapsed time, review effort, evidence-supported findings, false alarms, and disagreements with reference assessments. If a fixed classification rule is agreed in advance, report the confusion matrix, precision, recall, F1, and false-positive rate with sample counts and uncertainty. Account for unknown/failed analyses separately rather than silently excluding them.

No custom model training is required by the proposal. A successful result is a working, evaluated integration with transparent limitations, not a claim of universal malware detection. [P, pp.5-7]

Client decisions and recommended priorities

These questions resolve scope and acceptance. They are recorded for the client discussion; this requirements review does not depend on answering all of them immediately.

Priority / owner	Decision to obtain	Why it matters
P0 Client + supervisor	Is a clearly labeled supervised OpenBin import acceptable if automation cannot be proven?	Determines the central workflow, operator effort, demo expectations, and realistic delivery commitment.
P0 Client + developer	May the trusted application server temporarily receive the private key and plaintext, or must crypto stay on the user's device?	Changes the privacy promise and where encryption/decryption must run.
P0 Team + supervisor	Who checks AI evidence and signs off reviewed findings? May that person access another user's code?	Defines review permissions, accountability, and the meaning of a completed result.
P0 Client	What is the submission/demo date, budget, development responsibility, and available computer/server?	The proposal's 22 weeks is an estimate, not a confirmed deadline or price.
P0 Client + developer	Which accounts, API keys, model/provider, spending limits, and cloud-data consent are available?	Determines permitted integrations, confidentiality boundaries, and operating cost.
P1 Supervisor + team	Which PE variants and document types are supported; who supplies the authorized labeled test set?	Resolves native/.NET, DLL/EXE, packed-file handling, test coverage, and academic evaluation.
P1 Client + developer	Who generates keys, which formats/passphrases are accepted, and must a recipient register?	Defines key onboarding and recovery usability without implying key escrow.
P1 Client + developer	What numeric upload/pixel/job limits, retention/deletion policy, and admin actions are required?	Controls storage, resources, privacy, and testable operating limits.
P1 Client + supervisor	Which final documents, diagrams, test evidence, deployment/demo environment, and handover support are expected?	Prevents documentation, hosting, and maintenance from becoming unpriced assumptions.

Recommended scope priority

Must deliver: accounts/ownership, supported PE validation, the agreed OpenBin workflow, source-separated reputation findings, consent, safe processing, encryption/hiding/recovery, history, PDF reports, basic administration, evaluation, and documentation.

Should deliver: clear job progress, bounded retry/caching, cleanup after failure, reproducible setup, and key-use guidance. These support a credible demonstration even when a provider is unavailable.

Defer unless requested: email-based account recovery, browser-only cryptography, automatic key generation, more file formats, custom model training, public file sharing, and commercial deployment.

Delivery sequence and source register

Proposal schedule: 22 weeks, subject to the real deadline

Weeks	Proposal activity / recommended checkpoint
1-2	Requirements and literature review. Resolve P0 decisions and agree acceptance criteria.
3-4	Evaluation sample selection and OpenBin setup. Prove one end-to-end path and select automation or supervised import.
5-6	System/database design. Agree data flows, key handling, package format, limits, and interface.
7-8	Interface and authentication. Demonstrate ownership restrictions and consent.
9-11	OpenBin CLI/static-analysis workflow. Demonstrate isolation, job states, errors, and provenance.
12-14	AI findings integration and evaluation. Demonstrate evidence review and record quality metrics.
15-17	Reputation API and document protection. Prove exact recovery and negative cases.
18	Scan history and PDF reports. Verify report/result consistency.
19-20	System tests and improvements. Complete acceptance checklist and demo rehearsal.
21-22	Documentation and presentation. Deliver source, setup, tests, user guide, and final report.

Schedule follows [P, p.6]; checkpoints are recommendations. No new fixed-price or shortened-time estimate is justified yet. First technical implementation work should validate the uncertain integration path before building the complete interface.

Handover baseline

Working web prototype; evaluated analysis workflow; reputation integration; document encryption/hiding/recovery; accounts/history; scan PDFs; source code; test results; user guide; and final project documentation. Recommend adding reproducible setup instructions, environment template, database migrations, version/configuration record, and a demo script. [P, p.6]

Sources and evidence limits

P. Client proposal: FYP_Updated_Proposal (1).pdf, seven pages. Sections 4-8 establish scope/workflows; sections 9-11 cover technology/security/evaluation; sections 13-14 cover schedule/deliverables. User confirmed university FYP scope.

W1. OpenBin official overview / standard local CLI workflow

W2. BINNY official repository: local workflow, findings, models, license

W3. VirusTotal: public versus premium API restrictions

W4. VirusTotal: retrieve a file report by hash

W5. Python cryptography: authenticated encryption

W6. Python cryptography: RSA / OAEP

Official sources checked 29 October 2026. Web documentation supports feasibility observations, not proof that a particular installed version or account works. Recheck selected versions and service terms during setup. No development or malware testing was performed for this analysis.